

CVEs más relevantes de la semana

Del 14/07/2026 al 21/07/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-50330

Descripción: Heap-based buffer overflow in Remote Desktop Client allows an unauthorized attacker to elevate privileges over a network.

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-50439

Descripción: Use after free in Microsoft Message Queuing Queue Manager allows an unauthorized attacker to execute code over a network.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-57089

Descripción: Use after free in Windows SMB Server Network Transport Driver (srvnet.sys) allows an unauthorized attacker to execute code over a network.

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-57090

Descripción: Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-58594

Descripción: Integer overflow or wraparound in Windows RDP allows an unauthorized attacker to execute code over a network.

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-58617

Descripción: Improper access control in Microsoft 365 Copilot for iOS allows an unauthorized attacker to elevate privileges over a network.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-45063

Descripción: Symfony is a PHP framework for web and console applications and a set of reusable PHP components. Prior to 5.4.52, 6.4.40, 7.4.12, and 8.0.12, X509Authenticator extracts the user identifier from `$_SERVER['SSL_CLIENT_S_DN']` with an unanchored regex that matches `emailAddress=` anywhere in the distinguished name, allowing an attacker with a trusted certificate containing `emailAddress=victim` inside ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-45069

Descripción: Symfony is a PHP framework for web and console applications and a set of reusable PHP components. Prior to 6.4.40, 7.4.12, and 8.0.12, `OidcTokenHandler::verifyClaims()` registered audience (aud), issuer (iss), and expiry (exp) checkers but did not pass the mandatory claims list to `ClaimCheckerManager::check()`, so a validly signed JWT that omitted those claims could pass verification. This issue ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-47767

Descripción: Symfony is a PHP framework for web and console applications and a set of reusable PHP components. From 5.4.46 until 5.4.52, 6.4.40, 7.4.12, and 8.0.12, the CVE-2024-50340 fix gated runtime argv parsing on empty(\$_GET), but parse_str() and the web SAPI can disagree, allowing a crafted query string to leave \$_GET empty while \$_SERVER['argv'] still carries attacker-controlled --env or --no-debug f...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-436

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-47984

Descripción: Adobe Commerce is affected by an Incorrect Authorization vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized read and write access. Exploitation of this issue does not require user interaction.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-47988

Descripción: Adobe Commerce is affected by an Incorrect Authorization vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized read and write access. Exploitation of this issue does not require user interaction.

CVSS: 8.6 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48356

Descripción: Adobe Commerce is affected by an Unrestricted Upload of File with Dangerous Type vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to inject malicious scripts into a web page, potentially gaining elevated access or control over the victim's account or session. Exploitation of this issue requires user inte...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:L

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48358

Descripción: Adobe Commerce is affected by an Improper Encoding or Escaping of Output vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-116

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-24227

Descripción: NVIDIA TensorRT for contains a vulnerability where a user might cause a deserialization of untrusted data. A successful exploit of this vulnerability might lead to code execution.

CVSS: 5.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48284

Descripción: ColdFusion is affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48319

Descripción: ColdFusion is affected by an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48320

Descripción: ColdFusion is affected by a reflected Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this vulnerability to inject malicious scripts into a web page, potentially gaining elevated access or control over the victim's account or session. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is changed.

CVSS: 8.5 (HIGH)

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48321

Descripción: ColdFusion is affected by an Incorrect Authorization vulnerability that could result in privilege escalation. An attacker could leverage this vulnerability to gain unauthorized read and write access. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48322

Descripción: ColdFusion is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48324

Descripción: ColdFusion is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-46633

Descripción: Twig is a template language for PHP. Prior to 3.26.0, `Compiler::string()` does not escape single quotes when a template name from a `{% use %}` tag is placed inside a PHP single-quoted string literal, allowing a crafted template name to terminate the string and inject arbitrary PHP expressions into the compiled cache file. This issue is fixed in version 3.26.0.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-46634

Descripción: Twig is a template language for PHP. From 3.9.0 until 3.26.0, `template_from_string()` compiles an inner template under a synthesized `__string_template__<hash>` name that can fall outside a `SourcePolicyInterface` sandbox decision, allowing a sandboxed template that can call `template_from_string` and `include` to render an inner template without security policy enforcement. This issue is fixed in versi...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-693

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48334

Descripción: Illustrator is affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is changed.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48805

Descripción: Twig is a template language for PHP. Prior to 3.27.0, deprecated internal wrappers in `src/Resources/core.php` do not forward the current sandbox state to `CoreExtension::checkArrow()`, `arraySome()`, and `arrayEvery()`, allowing legacy calls such as `twig_array_some()`, `twig_array_every()`, and `twig_check_arrow_in_sandbox()` to bypass sandbox callable restrictions. This issue is fixed in version 3.27.0.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-693

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48806

Descripción: Twig is a template language for PHP. Prior to 3.27.0, ArrayExpression does not guard dynamic mapping keys that are coerced to strings, allowing PHP to invoke `__toString()` on a Stringable object used as a mapping key without calling `SandboxExtension::ensureToStringAllowed()`. This issue is fixed in version 3.27.0.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-693

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48807

Descripción: Twig is a template language for PHP. Prior to 3.27.0, the sandbox `__toString()` checks do not fully cover Traversable values passed to join and replace filters or operands evaluated by the in and not in operators, allowing contained Stringable objects to be coerced to strings without consulting the sandbox policy. This issue is fixed in version 3.27.0.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-693

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-56398

Descripción: Open WebUI before 0.9.5 contains a stored cross-site scripting vulnerability in the OAuth authentication flow where the picture claim URL MIME type is inferred from file extension rather than Content-Type header, allowing SVG files to bypass the profile image validator and be stored as data URIs. Authenticated users who visit the profile image endpoint receive attacker-controlled SVG content wi...

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:N

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-07-15



CVE-2026-56400

Descripción: open-webui before 0.3.14 contains a cross-origin resource sharing misconfiguration allowing arbitrary origins with `allow_origins=*` and authenticated requests to the `/api/v1/functions` endpoint. Attackers can execute arbitrary code on the openwebui instance by crafting malicious cross-site requests from attacker-controlled websites when an admin user visits them.

CVSS: 8.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-613

Tecnología: No especificado

Publicado el: 2026-07-15



CVE-2026-53512

Descripción: Better Auth is an authentication and authorization library for TypeScript. Prior to 1.6.11, the legacy oidcProvider and mcp plugins expose OAuth token endpoints whose refresh_token grant authenticates only possession of the bound refreshToken row and matching client_id, without verifying the confidential client's client_secret, allowing an attacker with a valid refresh_token to mint access token...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-07-15



CVE-2026-54052

Descripción: n8n-MCP is an MCP server that provides AI assistants access to n8n node documentation, properties, and operations. Prior to 2.56.1, in HTTP mode with multi-tenancy enabled through `ENABLE_MULTI_TENANT=true`, n8n-mcp's local workflow version history backups were not isolated per tenant, allowing an authenticated tenant to read workflow version snapshots belonging to other tenants and delete or des...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:L

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-07-15



CVE-2026-56453

Descripción: HCL DFXAnalytics is affected by an Account Takeover via Response Manipulation vulnerability. A remote attacker can intercept and alter the contents of the server's HTTP responses before they reach the client application, allowing them to manipulate the authentication or authorization logic to bypass controls and gain unauthorized access to targeted user accounts.

CVSS: 5.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:L/I:L/A:L

Tipo: CWE-294

Tecnología: No especificado

Publicado el: 2026-07-16



CVE-2026-44596

Descripción: Yamcs is a mission control framework. Prior to 5.12.7, the authentication endpoint POST /auth/token in yamcs-core, handled by yamcs-core/src/main/java/org/yamcs/http/auth/AuthHandler.java, lacked any rate limiting, account lockout, or failed-attempt throttling, so an unauthenticated remote attacker could perform unlimited password-guessing attempts against any user account, significantly increa...

CVSS: 6.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Tipo: CWE-307

Tecnología: No especificado

Publicado el: 2026-07-16



CVE-2026-45568

Descripción: zrok is software for sharing web services, files, and network resources. Prior to 2.0.3, zrok's Python SDK ProxyShare Flask proxy route accepts an absolute URL in the request path and passes it to `urllib.parse.urljoin`, allowing the requested path to replace the configured target host and causing requests.request to return a server-side response from an attacker-chosen URL. This issue is fixed i...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-07-16



CVE-2026-12692

Descripción: Unverified password change vulnerability in Vimesoft Inc. Enterprise Video Platform allows Authentication Bypass.

This issue affects Enterprise Video Platform: from 3.11.0.0 before 3.25.0.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-620

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-8297

Descripción: Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Gis Informatics Engineering Consulting Laboratory R&D and Software Services Inc. GisLab Laboratory Management System allows SQL Injection.

This issue affects GisLab Laboratory Management System: from 1.4.03 through 08072026.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-13448

Descripción: IBM Langflow OSS 1.0.0 through 1.10.1 Lanflow OSS contains an unauthenticated remote code execution vulnerability in the public flow build endpoint (`/api/v1/build_public_tmp/{flow_id}/flow`). The vulnerability stems from an incomplete denylist in the `validate_public_flow_no_code_execution()` function that fails to block several code-execution agent components including OpenDsStarAgent, CodeActA...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-8481

Descripción: IBM Langflow OSS 1.0.0 through 1.10.0 contain a critical remote code execution vulnerability in the code validation API endpoint. The POST /api/v1/validate/code endpoint accepts user-supplied Python code and executes it directly using Python's built-in exec() function without sandboxing, input validation, or privilege restrictions, enabling any authenticated user to execute arbitrary system com...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-64625

Descripción: AVideo before 29.0 contains an incomplete fix for CVE-2026-45578 where `execAsync()` re-wraps escaped commands in double-quoted `sh -c`, allowing command substitution via `$()` and backticks. Attackers can inject arbitrary OS commands through the Live plugin `on_publish.php` endpoint despite `escapeshellarg()` protection.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-07-20



CVE-2026-65007

Descripción: The Grav api plugin (grav-plugin-api) before 1.0.8 fails to properly authorize API key generation and revocation: the plugin intercepts the apiKeyGenerate/apiKeyRevoke admin tasks before the account-management ACL runs and authorizes the caller on only the admin.login permission (the baseline permission held by every panel user). This allows any user with admin.login to mint a persistent API ke...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-65008

Descripción: Grav 2.0.4 (fixed in 2.0.7) contains a remote code execution vulnerability in `Blueprint::dynamicData()` (`system/src/Grav/Common/Data/Blueprint.php`), which passes a `Class::method` callable string and its arguments directly to `call_user_func_array()` without any allowlist. Because the form plugin routes page frontmatter through this path, an authenticated account with the `admin.pages` (or `api.pages.w...`

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28302

Descripción: SolarWinds Serv-U is affected by an insecure direct object reference (IDOR) vulnerability that can lead to privilege escalation and remote code execution as root. This issue requires group administrator access. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28304

Descripción: SolarWinds Serv-U is affected by a remote code execution vulnerability that, when exploited, can allow the arbitrary execution of code remotely as root. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28305

Descripción: SolarWinds Serv-U is affected by an insecure direct object reference (IDOR) vulnerability that can lead to remote code execution as root. A domain account with admin privileges and read and write access to the home directory is required. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28306

Descripción: SolarWinds Serv-U is affected by a privilege escalation vulnerability that allows a domain administrator to elevate their privileges to a system administrator. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28307

Descripción: SolarWinds Serv-U is affected by a privilege escalation vulnerability that allows a domain user group to be elevated into an administrator group. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28308

Descripción: SolarWinds Serv-U is affected by an insecure direct object reference (IDOR) vulnerability that can lead to remote code execution. Domain administrator access is required. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28309

Descripción: SolarWinds Serv-U is affected by a broken access control vulnerability that allows a domain administrator to create system administrator accounts. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28310

Descripción: SolarWinds Serv-U is affected by a privilege escalation vulnerability that allows a domain administrator to escalate their user type to that of a system administrator. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28312

Descripción: SolarWinds Serv-U is affected by a privilege escalation vulnerability. This would elevate a group's access to system administrator and allow code execution as root. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-285

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28313

Descripción: SolarWinds Serv-U is affected by an insecure direct object reference (IDOR) vulnerability that can lead to SMTP hijacking leading to arbitrary account takeover. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28314

Descripción: SolarWinds Serv-U is affected by an insecure direct object reference vulnerability that leads to an account takeover. User authentication is required. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28316

Descripción: SolarWinds Serv-U is affected by an insecure direct object reference (IDOR) vulnerability that can lead to privilege escalation to a system administrator with the ability to execute commands as the root user. This issue requires a domain account with administrator access. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28317

Descripción: SolarWinds Serv-U is affected by an insecure direct object reference (IDOR) vulnerability that can lead to privilege escalation. This issue requires domain administrator access. The impact is lower in Windows deployments.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-28321

Descripción: SolarWinds Serv-U is affected by a broken access control vulnerability that could allow arbitrary file read and write, which can then be used to escalate privileges and execute code as root. A domain administrator access is required, and the impact is lower in Windows installations.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-07-21



CVE-2026-64825

Descripción: Home Assistant Core before 2026.6.0 contains a path traversal vulnerability that allows unauthenticated attackers to write arbitrary files to any directory on the host filesystem by uploading a crafted backup archive during the initial onboarding window. Attackers can manipulate the 'name' field inside the uploaded archive's backup.json to supply an absolute path, causing pathlib.Path.__truediv...

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:H/A:L

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-07-21



Resumen del Reporte

CVEs analizados: 55

Promedio CVSS: 8.88

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

